Unit I

Computer Security Concepts

Introduction

The requirement of information security within an organization has undergone two major changes in last few decades. Before the widespread use of the data processing equipments, the security of information felt to be valuable to an organization was provided primarily by physical and administrative means. The example of the former is the use of cabinets (cupboard) with a combination of lock for storing sensitive documents/files.

With an introduction of the computer, the need for automated tools for protecting files and other information stored on the computer became evident. This is especially the case for a shared system, such as time-sharing system, and need for acute for the system that can be accessed over public telephone network or data network or the Internet. The generic name of combination of tools designed to protect data is called Computer Security.

The second major change that affected security is the introduction of distributed system and the use of networks and communications facilities for carrying data between terminal user and computer and between computers to computers. Network security measures are needed to project the data during their transmissions.

The OSI Security Architecture.

To assess effectively the security needs of an organization and to evaluate and Choose various security products and policies, the manager responsible for security needs some systematic way of defining the requirements for security and characterizing the approaches to satisfying those requirements. This is difficult enough in a centralized data processing environment; with the use of local and wide area networks, the problems are compounded.

ITU (International Telecommunication Union) Recommendation X.800, Security Architecture for OSI, defines such a systematic approach. The OSI security architecture is useful to managers as a way of organizing the task of providing security. Furthermore, because this architecture was developed as an international standard, computer and communications vendors have developed security features for their products and services that relate to this structured definition of services and mechanisms. For our purposes, the OSI security architecture provides a useful, if abstract,

overview of many of the concepts that this book deals with. The OSI security architecture focuses on security attacks, mechanisms, and services. These can be defined briefly as

- **Security attack:** Any action that compromises the security of information owned by an organization.
- **Security mechanism:** A process that is designed to detect, prevent, or recover from a security attack.
- **Security service:** A processing or communication service that enhances the security of the data processing systems and the information transfers of an organization. The services are intended to counter security attacks, and they make use of one or more security mechanisms to provide the service.

1) Security Attacks:

A useful means of classifying security attacks, used both in X.800 and RFC 4949, is in terms of passive attacks and active attacks (Figure 1.2). A passive attack attempts to learn or make use of information from the system but does not affect system resources. An active attack attempts to alter system resources or affect their operation.

a) Passive Attacks

Passive attacks are in the nature of eavesdropping on, or monitoring of, transmissions. The goal of the opponent is to obtain information that is being transmitted. Two types of passive attacks are the release of message contents and traffic analysis.

The release of message contents is easily understood. A telephone conversation, an electronic mail message, and a transferred file may contain sensitive or confidential information. We would like to prevent an opponent from learning the contents of these transmissions.

A second type of passive attack, **traffic analysis**, is subtler. Suppose that we had a way of masking the contents of messages or other information traffic so that opponents, even if they captured the message, could not extract the information from the message. The common technique for masking contents is encryption. If we had encryption protection in place, an opponent might still be able to observe the pattern of these messages. The opponent could determine the location and identity of communicating hosts and could observe the frequency and length of messages being exchanged. This information might be useful in guessing the nature of the communication that was taking place. Passive attacks are very difficult to detect, because they do not involve any alteration of the data. Typically, the message traffic is not sent and received in an apparently normal

fashion and the sender nor receiver is aware that a third party has read the messages or observed the traffic pattern. However, it is feasible to prevent the success of these attacks, usually by means of encryption. Thus, the emphasis in dealing with passive attacks is on prevention rather than detection.

b) Active Attacks

Active attacks involve some **modification of the data stream** or the creation of a false stream and can be subdivided into four categories: masquerade, replay, modification of messages, and denial of service.

A masquerade attack is when a bad person pretends to be someone else to gain access to things they shouldn't have access to. This usually happens by stealing or copying a legitimate user's login details, like their username and password. **Replay** involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect.

Modification of messages simply means that some portion of a message is altered, or that messages are delayed or reordered, to produce an unauthorized effect.

The **denial of service** prevents or inhibits the normal use or management of Communications facilities this attack may have a specific target; for example, an entity may suppress all messages directed to a particular destination.

2) Security Services

X.800 & RFC 2828 defines security services as a service provided by protocol layer of communicating Operating Systems, which provides adequate security of the system or data transfer. Security services implements security polices and are implemented by security mechanism. X.800 divided the services in as per following categories.

- **Authentication:** The assurance that the communicating entity is the one that it claims to be.
- **Access Control:** The Prevention of unauthorized use of system resources i.e. service controls who can have access to a resources, under what conditions access can occur.
- **Data Confidentiality:** Assures the protection of data from unauthorized disclosure i.e. Private or confidential information is not made available or disclosed to unauthorized individuals.
- **Data Integrity:** Assures that the data received are exactly as sent by an authorized entity which contains no modification, insertion, deletion or replay.

- **Nonrepudiation:** Nonrepudiation prevents either sender or receiver from denying a transmitted message. Thus, when the message is sent, the receiver can prove that the alleged sender in fact sent the message. Similarly, when a message is received, the sender can prove that the alleged (supposed) receiver in fact receives the message.
- **Availability:** Both X.800 and RFC 4949 define availability to be the property of a system and a system resource being accessible and usable upon demand by an authorized system entity, according to performance specifications for the system (i.e., a system is available if it provides services according to the system design whenever users request them). A variety of attacks can result in the loss of or reduction in availability.

3) Security Mechanism

The mechanisms are divided into those that are implemented in a specific protocol layer, such as TCP or an application-layer protocol, and those that are not specific to any particular protocol layer or security service.

- **Encryption:** The use of mathematical algorithms to transform data into a form that is not readily intelligible. The transformation and subsequent recovery of the data depend on an algorithm and zero or more encryption keys.
- **Digital Signature:** Data appended to, or a cryptographic transformation Of, a data unit that allows a recipient of the data unit to prove the source and integrity of the data unit and protect against forgery (e.g., by the recipient).

  Access Control: A variety of mechanisms that enforce access rights to resources. Data Integrity A variety of mechanisms used to assure the integrity of a data unit or stream of data units.

A model for Network Security:

A model for much of what we will be discussing is captured, in very general terms as indicated in following. A message is to be transferred from one party to another across some sort of Internet service. The two parties, who are the principals in this transaction, must cooperate for the exchange to take place. A logical information channel is established by defining a route through the Internet from source to destination and by the cooperative use of communication protocols (e.g., TCP/IP) by the two principals. Security aspects come into play when it is necessary or desirable to protect the information transmission from an opponent who may present a threat to confidentiality, authenticity, and so on. All the techniques for providing security have two components:

- A security-related transformation on the information to be sent. Examples

include the encryption of the message.

- Some secret information shared by the two principals and, it is hoped, unknown to the opponent.

A trusted third party may be needed to achieve secure transmission. For example, a third party may be responsible for distributing the secret information

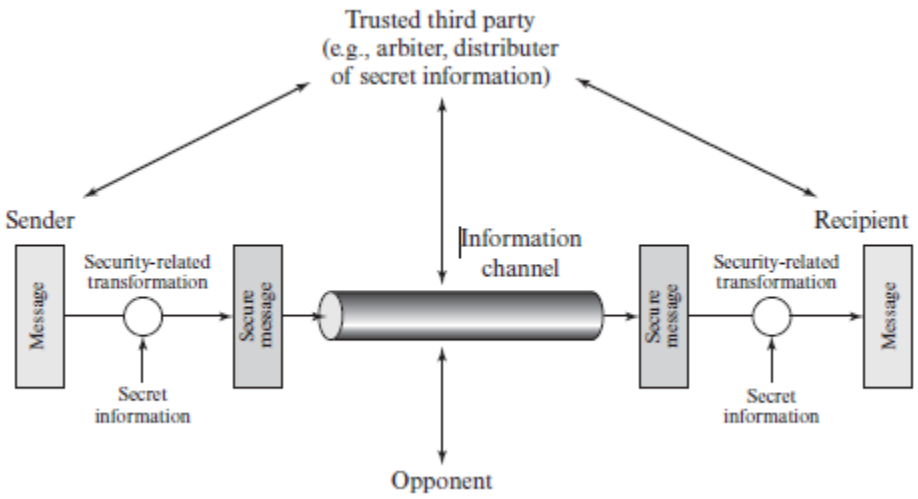

Fig.: A Model for Network Security

The Challenges in computer Security

Computer security, also known as cyber security, is crucial in protecting data, systems, and networks from various threats. However, numerous challenges exist in maintaining effective security. Some of the key challenges include:

1. Evolving Threat Landscape

- Cyber threats are continuously evolving, with new techniques, tools, and attack methods being developed by malicious actors. Examples include ransom ware, phishing.
- The constant need to stay updated on emerging threats is a significant challenge.

2. Human Error

- Users are often the weakest link in security. Simple mistakes such as weak passwords, falling for phishing scams, or mishandling sensitive data can compromise security.
- Social engineering tactics often exploit human psychology, making it difficult to fully safeguard systems from attacks.

3. Complexity of Systems

- Modern computer systems are highly complex, with interdependent hardware, software, and networks. This complexity increases the attack surface, providing more opportunities for cybercriminals to exploit vulnerabilities.
- Many systems are not patched regularly, leaving known vulnerabilities exposed.

4. Insider Threats

- Employees or trusted individuals with access to systems and data can intentionally or unintentionally cause harm, such as leaking sensitive information or introducing malware.
- Insider threats are harder to detect because the attackers already have authorized access.

5. Supply Chain Vulnerabilities

- Third-party vendors and software providers can be a source of security risks. If a vendor's system is compromised, it can affect all organizations relying on their services or products.
- The 2020 Solar Winds attack demonstrated how vulnerability in a third-party product could be exploited to target thousands of organizations.

6. Resource Limitations

- Many organizations, especially small businesses, lack the financial or human resources to implement robust cyber security measures.
- Limited budgets, understaffed security teams, and inadequate training can all contribute to vulnerabilities.
-

7. Cloud Security

- As businesses move to the cloud, they face new security challenges in managing data storage, access controls, and multi-tenant environments.
- The shared responsibility model in cloud computing means that while cloud providers handle some security aspects, customers are still responsible for securing their data and applications.

8. AI and Machine Learning Risks

- While AI can be used to enhance cyber security efforts (e.g., detecting anomalies), cybercriminals are also using AI to launch more sophisticated attacks.
- AI-driven attacks, such as deep fake fraud or automated social engineering, can bypass traditional security defenses.

09. Lack of Security Awareness

- Many organizations do not prioritize cyber security training for their employees. Without understanding best practices, employees may inadvertently contribute to security breaches.
- Regular training and awareness programs are essential but often overlooked.

Threats & Attacks:

In computer security, threats and attacks refer to the various methods that malicious actors use to compromise the confidentiality, integrity, and availability of computer systems, networks, and data. Below are some of the most common types of threats and attacks in cyber security:

1. Malware (Malicious Software)

- **Viruses:** Programs that attach themselves to legitimate files and spread when these files are executed or transferred. They can corrupt or delete files, damage systems, and steal information.
- **Worms:** Self-replicating malware that spreads across networks without needing to attach itself to files. Worms can consume network resources and cause significant damage.
- **Trojan Horses:** Malware disguised as legitimate software. Once installed, it can give attackers access to systems and allow them to steal data, install additional malware, or take control of the system.

- **Ransom ware:** A type of malware that encrypts the victim's files and demands a ransom (often in crypto currency) in exchange for the decryption key.
- **Spyware:** Software that secretly monitors and collects a user's activities, often to steal sensitive information like login credentials or credit card numbers.

2. Phishing

- **Phishing:** A fraudulent attempt to obtain sensitive information (like usernames, passwords, and credit card details) by disguising oneself as a trustworthy entity in electronic communications, often through email.

In computer security, **threats** and **assets** are two fundamental concepts that are crucial in understanding and protecting information systems. Below is an explanation of each concept and how they relate to each other.

1. Assets

Assets are the valuable resources or components within a system that need to be protected. In cyber security, assets typically refer to anything of value that is part of an organization's information technology infrastructure and operations. These can include:

- **Data**: Sensitive information, such as personal details, financial records, intellectual property, trade secrets, customer databases, and more.
- **Hardware**: Physical components like servers, computers, networking devices, and storage devices.
- **Software**: Applications, operating systems, and security software that are crucial to the organization's daily functions.
- **Network**: Communication networks, including the internet, intranet, local area networks (LANs), and wide-area networks (WANs) that connect systems.
- **People**: Employees, contractors, and users who interact with the systems, applications, and data, often considered a critical asset because their actions (good or bad) influence security.
- **Reputation**: The organization's reputation is an intangible but highly valuable asset. A compromised reputation due to a security breach can have long-lasting effects.
- **Intellectual Property (IP)**: Patents, trademarks, copyrights, and proprietary algorithms that represent valuable ideas or innovations.

- **Processes**: Business workflows, critical operational processes, and services provided by the organization.

2. Threats

Threats are potential causes of harm to an organization's assets. These are events or actions that can exploit vulnerabilities in a system to compromise or damage assets, causing loss or disruption. Threats can be intentional (e.g., cyber attacks) or accidental (e.g., human error). Common types of threats include:

- **Cyber attacks**: Malicious actions by attackers that seek to exploit vulnerabilities in systems, networks, or software to gain unauthorized access, steal data, or cause damage.

  Examples: Hacking, ransom ware.

- **Natural Disasters**: Events like earthquakes, floods, fires, or storms that can physically damage hardware, infrastructure, or facilities, and disrupt services.
- **Human Error**: Mistakes made by employees or users that lead to accidental exposure of sensitive data, loss of data, or incorrect configurations in systems.
  - Examples: Sending sensitive data to the wrong person, misconfiguring security settings, or clicking on phishing links.
- **Insider Threats**: Threats posed by individuals within the organization who misuse their access privileges to intentionally or unintentionally cause harm.
  - Examples: Employees leaking confidential information or selling data to competitors, or unwittingly causing damage through negligence.
- **Malware**: Software specifically designed to disrupt, damage, or gain unauthorized access to computer systems or networks.
  - Examples: Viruses, worms, Trojan horse , ransom ware, spyware, etc.
- **Social Engineering**: Manipulation tactics used to mislead individuals into exposing confidential information or taking actions that compromise security.
  - Examples: Phishing, pre-texting, baiting.
- **Physical Theft or damage**: Physical threats that involve stealing devices or data, or intentionally damaging infrastructure.
  - Examples: Stealing a laptop or sabotaging server hardware.

- **Third-Party Risk**: Threats that come from vendors, contractors, or other third-party partners who have access to the organization's systems or data.

  Examples: Supply chain attacks, where a compromised vendor introduces malware into the organization's network.

Relationship between Threats and Assets

The relationship between threats and assets is at the core of risk management in cyber security. **Threats** target **assets**, seeking to exploit vulnerabilities for malicious purposes. When assessing security risks, organizations typically evaluate:

- **What are the assets that need protection?** (e.g., sensitive customer data, intellectual property, or critical business processes)
- **What threats could affect these assets?** (e.g., hacking, natural disasters, employee mistakes)
- **What vulnerabilities could be exploited?** (e.g., un-patched software, weak passwords, misconfigured firewalls)

By understanding the threats to assets, an organization can prioritize which assets to protect and which threats to defend against, helping to implement appropriate security measures such as encryption, access control, backup strategies, security awareness training, and incident response plans.

Important Question (Assignment: I)

Q.1: What is Security? Explain OSI security architecture in detail.

Q.2: Explain a model for network security with figure.

Q.3: Write notes on following

1) Challenges in Computer Security.

2) Security threats & attacks.

3) Assets & threats

4) Relationship between assets & threats